

The background of the image features a dark blue gradient on the left, transitioning into a large, vibrant, abstract shape on the right. This shape is composed of overlapping curved segments in shades of orange, pink, and purple, creating a dynamic, modern aesthetic.

AWS re:Invent

NOV. 27 – DEC. 1, 2023 | LAS VEGAS, NV

STG324 - R

Advanced security patterns on Amazon S3

Bryant Cutler

Principal Engineer, Amazon S3
AWS

Akshat Sandh

Sr. Product Manager, Tech, Amazon S3
AWS



CONTENT WARNING:

**This talk is for AWS
security experts *only***

Ariel

can

get

objects in bucket1

if she uses TLS

```
"Statement": [ {  
  "Sid": "ExampleStatement01",  
  "Effect": "Allow",  
  "Principal": {  
    "AWS": "arn:aws:iam::123456789012:user/Ariel"  
  },  
  "Action": ["s3:GetObject"],  
  "Resource": [ "arn:aws:s3:::bucket1/*"],  
  "Condition": {  
    "Boolean": { "aws:SecureTransport": "true" }  
  }  
}
```

Devs

cannot

put

objects in bucket2

from outside the vpc

```
"Statement": [ {  
  "Sid": "ExampleStatement01",  
  "Effect": "Deny",  
  "Principal": {  
    "AWS": "arn:aws:iam::123456789012:role/dev"  
  },  
  "Action": ["s3:PutObject"],  
  "Resource": [ "arn:aws:s3:::bucket2/*"],  
  "Condition" : {  
    "StringNotEquals" : {"aws:SourceVpcId": "vpc-id" }  
  }  
}
```



Congratulations!

You are now an AWS security expert!
(relative to the global population)



Pattern for *configuring* Amazon S3

Pattern for *scaling* S3 access control



Pattern for *using* S3 in an application



Pattern for *operating* like S3

...

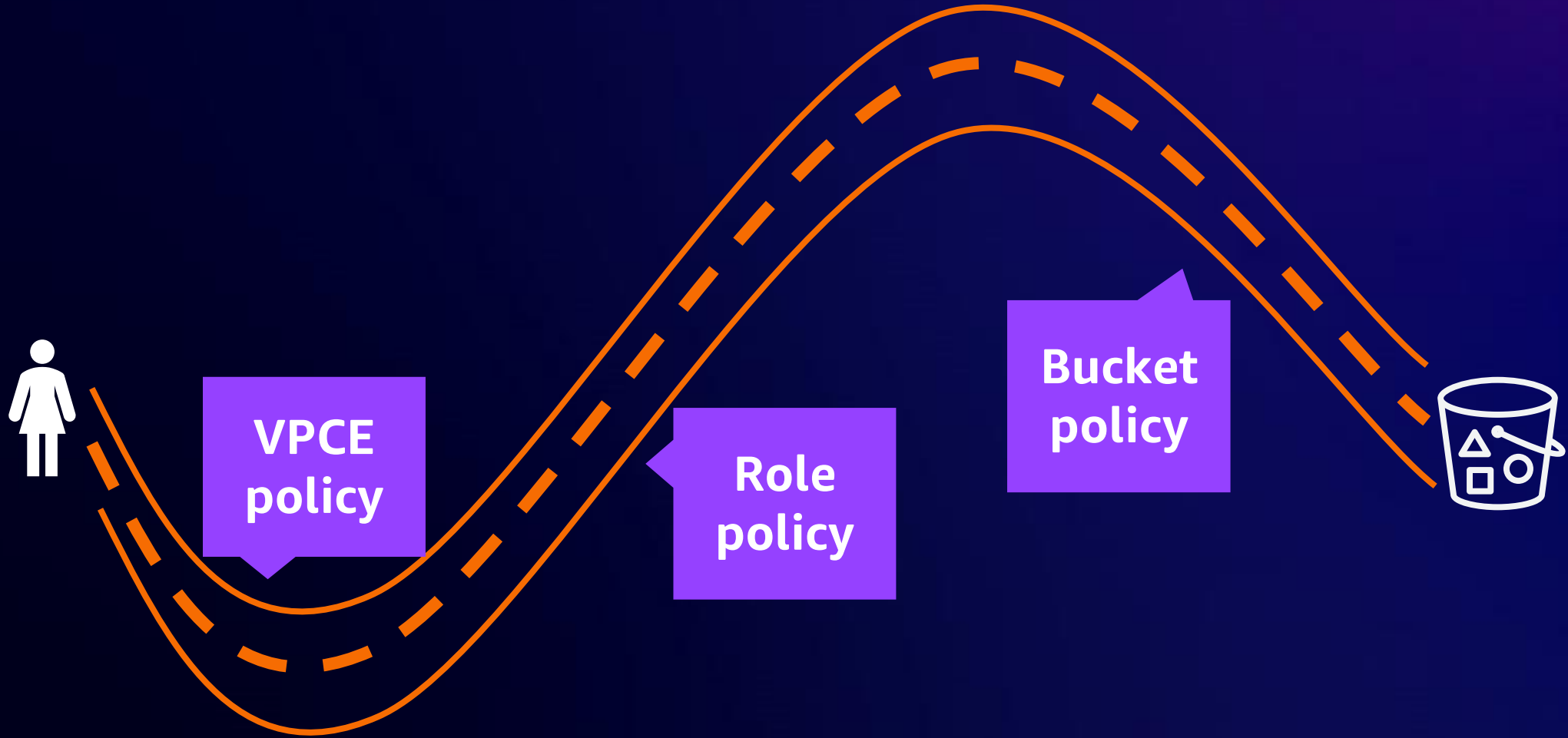


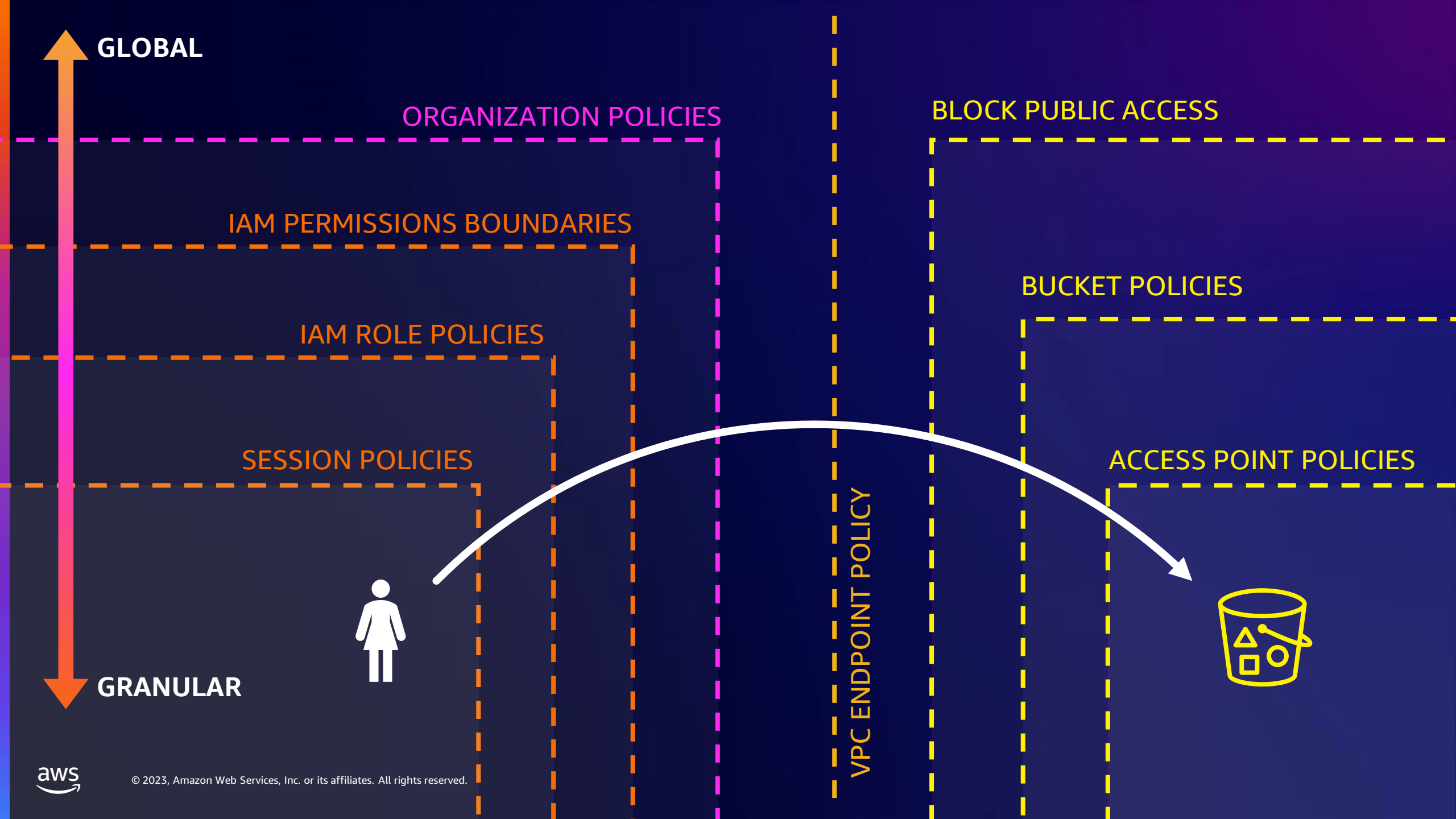
1

What are all these different policies used for?

Traditional access control mental model

THINKING OF POLICIES AS STOPS ON THE ROAD TO PROVIDING/RESTRICTING ACCESS





Advanced mental model

DIFFERENT POLICY TYPES TO ACCOMPLISH DIFFERENT POLICY GOALS

Boundaries

Enforce restrictions
Ensure compliance
Keep data safe

Paths

Enable applications
Enhance discoverability
Make data useful

BOUNDARIES

If I want to . . .

. . . I should use . . .

Require my enterprise to
use TLS or encryption type

AWS Organizations SCPs
S3 bucket policy

Make sure no data is
exfiltrated from my VPCs

VPCE policy

Prevent specific users
from viewing PII

AWS IAM permissions boundaries
S3 bucket policy

If I want to . . .

. . . I should use . . .

Share data with a
partner or application

S3 access point policy

Give a user temporary
access to data in S3

STS session policy

Give an AWS service
access to my S3 data

AWS IAM role policy *or*
S3 bucket policy

2

Scaling Amazon S3 access control with temporary credentials

Credentials
for authentication

Permissions
for authorization

Token Vending Machine

Short-term credentials

Just-in-time permissions

Granularity and control

Scaling trade-offs

Amazon S3 Access Grants



Govern data access across a complex organization

Ensure that the right data is accessed by the right user for the right purpose

- Enforce granular S3 access at scale
- Grant permissions directly to identities in external corporate directory
- End-to-end auditability

3

Secure data ingestion to Amazon S3

Design priorities

Ingest data safely from internet/partners

Data lake tools should see only vetted data

Serverless scalability

Inbox architecture

Serverless scalability

Push vs. pull models

Custom transforms

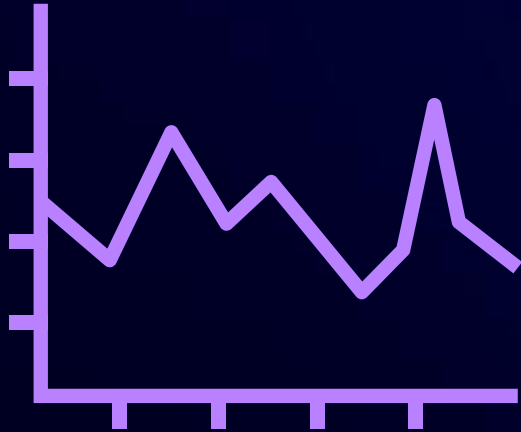


4

Evolving *your* security controls like Amazon S3

Evolving security features

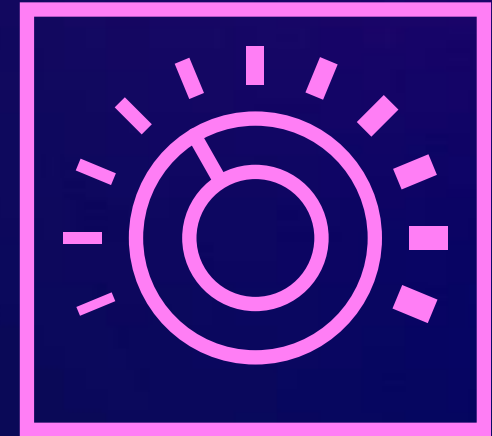
CONSIDERATIONS THAT DRIVE OUR DECISION-MAKING



EVALUATE



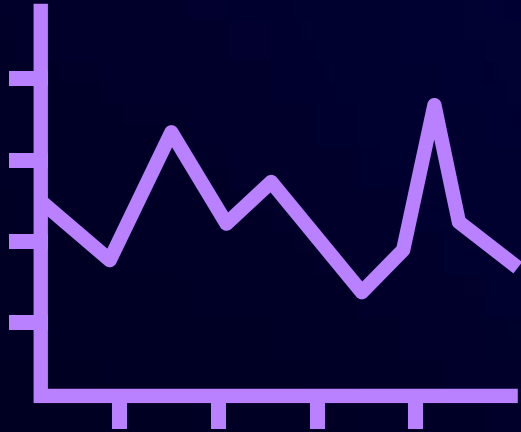
COMMUNICATE



CONTROL

Evolving security features

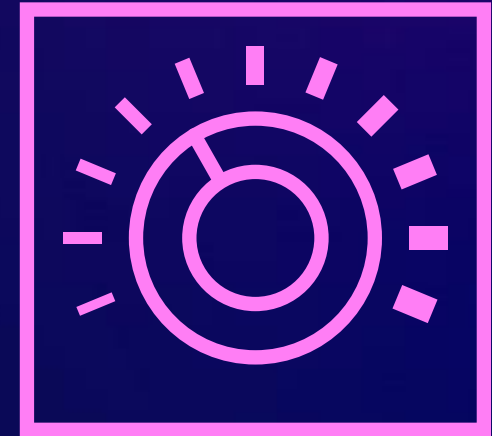
EXAMPLE: NOACL AND BPA BY DEFAULT



Months of metrics
Request sampling
Shadow mode



Pre-announcements
PHD updates
Customer meetings



Temporary extensions
for customers who
needed more time

Patterns recap

- 1 Mental model: boundaries and paths
- 2 Use Amazon S3 Access Grants or a custom TVM to scale access control
- 3 Amazon S3 and AWS Lambda can work together to preprocess data on ingestion into your data lake
- 4 Upgrade security the Amazon S3 way: shadow mode, transparency, per-user controls

Thank you!

Bryant Cutler

bcutler@amazon.com

Akshat Sandh

akssandh@amazon.com



Please complete the session
survey in the mobile app



Q&A

